COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.2 · Phishing

Mestre CyberSec · **Lesson 2.2 — Phishing** (6:32) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Fraude por email: phishing em massa; Spear phishing = alvo específico com contexto pessoal; Whaling = mirando EXECUTIVO (a baleia); Vishing = por voz (ligação); SMiShing = por SMS. Defesa: MFA, antispam, SPF/DKIM/DMARC (autentica o remetente), awareness.

💡 Key Exam Highlights & Critical Concepts

- Whaling = phishing mirando executivo (spear phishing de whale)
- Vishing = phishing por VOZ; SMiShing = por SMS
- SPF/DKIM/DMARC: o trio de autenticação de remetente de email

🎯 Exam Tips & Typical CompTIA Scenarios

- 'C-level executives target' = whaling
- 'phishing by voice call' = vishing

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.2 — Phishing)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Phishing (Mass Phishing) (N/A)

Email-based social engineering attack sent to a large number of recipients with no specific target, using generic lures to steal credentials or deliver malware.

⚠ ***Exam Trap:*** *If the question describes a broad, untargeted email campaign → it's plain 'Phishing'. As soon as it gets personal/targeted, it becomes Spear Phishing.*

• Spear Phishing (N/A)

Targeted phishing attack customized with personal or organizational context (name, role, projects) to increase credibility against a specific individual or group.

⚠ ***Exam Trap:*** *Trigger words: 'personalized', 'mentions your name/project', 'targeted individual'. Spear Phishing = targeted; Whaling = spear phishing aimed at executives.*

• Whaling (N/A)

Spear phishing attack aimed specifically at high-value C-level executives (CEO, CFO) whose access enables large financial fraud or strategic compromise.

⚠ ***Exam Trap:*** *Look for 'C-level', 'CEO', 'executive', 'CEO fraud / BEC'. Whaling = spear phishing aimed at the 'whale' (executive). Often paired with Business Email Compromise (BEC).*

• Vishing (Voice Phishing) (N/A)

Phishing attack conducted via voice telephone call, often using caller ID spoofing and urgency scripts to extract credentials or sensitive information.

⚠ ***Exam Trap:*** *Trigger words: 'phone call', 'caller ID spoofing', 'voice'. 'Phishing by voice call' = Vishing. Distinguish from Smishing (SMS).*

• SMiShing (SMS Phishing) (N/A)

Phishing attack delivered through Short Message Service (SMS) text messages, typically containing malicious links or prompts to call fraudulent numbers.

⚠️ ***Exam Trap:*** *Trigger words: 'text message', 'SMS', 'short code'. The 'SM' = Short Message. Don't confuse SMiShing (SMS) with Vishing (voice call).*

• Sender Policy Framework (SPF)

Email authentication DNS record that lists the authorized mail servers allowed to send email on behalf of a domain, helping prevent sender address spoofing.

⚠️ ***Exam Trap:*** *SPF = authorized SENDING servers (envelope sender). It does NOT validate the visible 'From:' header — that's where DKIM/DMARC come in.*

• DomainKeys Identified Mail (DKIM)

Email authentication method that cryptographically signs email messages, allowing the receiver to verify the message was not altered in transit and came from the claimed domain.

⚠️ ***Exam Trap:*** *DKIM = cryptographic SIGNATURE and integrity check. Pairs with SPF (who can send) and DMARC (policy on what to do when checks fail).*

• Domain-based Message Authentication, Reporting & Conformance (DMARC)

Email authentication policy that builds on SPF and DKIM by instructing receiving mail servers how to handle messages that fail authentication (quarantine, reject, or none) and provides reporting.

⚠️ ***Exam Trap:*** *DMARC = the POLICY layer. It needs BOTH SPF and/or DKIM to align. Trigger words: 'p=reject', 'p=quarantine', 'policy', 'reporting'. The trio is SPF + DKIM + DMARC.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A database administrator receives an email that appears to come from her direct manager. The message references her team's database migration project by its internal codename, mentions a meeting they both attended last Tuesday, and urges her to open an attached 'revised supplier invoice' before end of day. The attachment is named Invoice_Review.docm. Which type of attack is being described?

A) Whaling

B) Spear phishing

C) Vishing

D) Mass phishing

QUESTION 2 · EXAM SCENARIO

The CFO of a hospital network receives an urgent email that appears to be from the CEO. The CEO is publicly known to be boarding a flight at that exact moment, making a quick verbal confirmation impossible. The message instructs the CFO to wire $250,000 to a new vendor's account and to keep the transaction confidential 'until the acquisition is announced.' The sender address uses the domain hsp-network-corp.com instead of the hospital's real domain. What type of attack is this?

A) Whaling

B) Vishing

C) SMiShing

D) Mass phishing

QUESTION 3 · EXAM SCENARIO

An accounts payable clerk gets a phone call from someone claiming to work at the IT service desk. The caller states that suspicious logins were detected on the clerk's account and that the account will be permanently locked in 10 minutes unless she reads back the six-digit code that was just texted to her phone. What type of attack is this?

A) SMiShing

B) Spear phishing

C) Vishing

D) Whaling

QUESTION 4 · EXAM SCENARIO

Immediately after midnight, multiple employees receive the same SMS on their personal phones: 'FISCAL ALERT: a tax refund of $1,240 in your name is on hold. Confirm your direct-deposit details within 24 hours at hxxp://payrol1-verify.example-fin[.]net'. The link opens a form requesting bank account numbers and the company portal password. What type of attack is this?

A) Vishing

B) SMiShing

C) Mass phishing

D) Whaling

QUESTION 5 · EXAM SCENARIO

The mail gateway flags that overnight, 12,000 mailboxes across the organization received an identical email promising a '$100 retail gift card for verifying your account.' The message contains no recipient names, departments, or company-specific details, and its link points to a credential-harvesting page that imitates the corporate SSO login. Which attack type best describes this campaign?

A) Spear phishing

B) Whaling

C) Vishing

D) Mass phishing

QUESTION 6 · EXAM SCENARIO

A mail administrator wants receiving mail servers on the internet to verify that only systems approved by the company may send mail for the @corp-example.com domain. The requirement is to publish a DNS TXT record that enumerates the authorized sending IP addresses and hostnames so receivers can reject spoofed mail claiming to be from that domain. Which technology provides this capability?

A) DKIM

B) DMARC

C) SPF

D) A reverse DNS (PTR) record for the mail server

QUESTION 7 · EXAM SCENARIO

After a wave of invoice fraud, the security team asks which email authentication control signs every outbound message with a cryptographic key whose public counterpart is published in DNS, allowing receiving servers to verify that the message came from an authorized system and that its headers and body were not modified in transit. Which control is being requested?

A) SPF

B) DKIM

C) DMARC

D) STARTTLS

QUESTION 8 · EXAM SCENARIO

A CISO wants to stop spoofed messages that display the company domain in the visible From field. Two requirements must be met: receiving mail servers must quarantine or reject messages that fail authentication, and the company must receive aggregate reports showing who is attempting to send mail as the domain — including legitimate third-party marketing systems that are not yet authorized. Which implementation satisfies both requirements?

A) SPF configured with a softfail (~all) mechanism

B) DKIM keys rotated every 90 days with 2048-bit RSA

C) DNSSEC signing of the company zone

D) DMARC published with a policy of quarantine or reject

QUESTION 9 · EXAM SCENARIO

A payroll clerk clicked a link in a fraudulent email and entered her username and password into a page that imitated the company's Microsoft 365 login. She reported the incident within minutes, but the attacker now possesses valid credentials. Which already-deployed control will most directly prevent the attacker from using those captured credentials to access her mailbox?

A) Multi-factor authentication (MFA)

B) Full-disk encryption on her laptop

C) A host-based firewall on her laptop

D) Quarterly vulnerability scanning of the mail server

QUESTION 10 · EXAM SCENARIO

After a quarter in which 31% of staff clicked links in simulation exercises, the security manager is asked to select a preventive control that reduces click rates over time and also provides measurable trend data showing which departments remain most susceptible to email-borne social engineering. Which control best meets this goal?

A) Blocking all inbound email attachments at the mail gateway

B) Forcing password changes for all users every 30 days

C) Recurring security awareness training paired with simulated phishing campaigns

D) Increasing mailbox storage limits so users can archive more mail

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Spear phishing

The email is highly personalized (internal project codename and a shared meeting) and targets one specific individual with believable social context — the hallmark of spear phishing. Whaling is a form of spear phishing aimed specifically at senior executives (C-level), and the victim here is a database administrator. Vishing is carried out by voice (a phone call), not email. Mass phishing is a generic, non-personalized blast sent to large numbers of recipients and would not contain private project details.

Question 2: Option A — Whaling

The targets are the CFO (with the CEO impersonated) — senior executives — and the goal is a large fraudulent financial transaction with pressure for secrecy. This is the definition of whaling (also known as executive impersonation/CEO fraud). Vishing would involve a voice phone call. SMiShing is delivered via SMS text message. Mass phishing is a generic, untargeted campaign sent to large numbers of recipients, not a precisely tailored executive impersonation with a look-alike domain.

Question 3: Option C — Vishing

The attack is delivered by a live voice phone call — social engineering conducted over the phone is vishing. The caller's real goal is to harvest the one-time MFA code, which indicates the attacker likely already stole the clerk's password and needs the second factor to defeat multi-factor authentication. SMiShing is an attack delivered by SMS text; here the SMS is just the legitimate channel carrying the real MFA code. Spear phishing is a targeted email-based attack, and whaling targets senior executives.

Question 4: Option B — SMiShing

The malicious message is delivered via SMS text message, which by definition is SMiShing (SMS phishing). The look-alike domain with characters swapped is a common trick to make the link fit inside an SMS and to deceive users who skim it. Vishing is delivered by a voice call, not a text message. Mass phishing refers to bulk email campaigns. Whaling targets executives specifically, whereas here every employee's phone simply receives the same blast.

Question 5: Option D — Mass phishing

A single identical message sent in bulk to thousands of recipients with zero personalization is mass phishing — the attacker relies on volume and a small percentage of clicks rather than tailored social context. Spear phishing requires targeted, personal details about a specific recipient. Whaling is spear phishing limited to senior executives. Vishing would be delivered by voice call; this attack arrived by email.

Question 6: Option C — SPF

SPF (Sender Policy Framework) is exactly this mechanism: the domain owner publishes a DNS TXT record listing the IP addresses and hostnames authorized to send mail for the domain, and receiving servers check the actual sending server against that list. DKIM adds a cryptographic signature to each message rather than authorizing sending hosts. DMARC builds on top of SPF and DKIM results to enforce policy and generate reports, but does not itself enumerate authorized senders. A PTR record supports reverse lookups and mailbox reputation scoring, but it does not enumerate the approved senders of a domain.

Question 7: Option B — DKIM

DKIM (DomainKeys Identified Mail) attaches a digital signature to each message; the public key is published in DNS and receivers validate the signature to confirm both that the sending domain authorized the message and that the content was not tampered with (integrity). SPF only checks whether the sending IP address is authorized — it neither signs messages nor protects content. DMARC is a policy and reporting layer on top of SPF and DKIM alignment and does not perform the signing itself. STARTTLS encrypts the SMTP session in transit, but it is opportunistic, produces no persistent verifiable signature, and does not prove content authenticity.

Question 8: Option D — DMARC published with a policy of quarantine or reject

DMARC (Domain-based Message Authentication, Reporting & Conformance) satisfies both goals: it lets the domain owner define what receivers must do when SPF/DKIM fail to align with the visible From domain (p=quarantine or p=reject), and it sends aggregate and forensic reports back to the domain owner, revealing unauthorized senders — often legitimate third-party services — so they can be identified and authorized. An SPF softfail only marks mail as suspicious and provides no reporting. DKIM key rotation strengthens signatures but defines no policy for failed authentication. DNSSEC protects the integrity of DNS lookups for the zone, not email sender policy or reporting.

Question 9: Option A — Multi-factor authentication (MFA)

MFA requires an additional factor the attacker does not possess — such as a code from an authenticator app, a hardware token, or a biometric — so a stolen password alone is not enough to log in, which makes MFA the single most effective compensating control against phished credentials. Full-diskencryption protects data at rest on a stolen device, not account access from any location. A host-based firewall filters endpoint network traffic and does nothing to stop credential reuse from the attacker's machine. Vulnerability scanning looks for software flaws on the mail server, which was never compromised — only her credentials were.

Question 10: Option C — Recurring security awareness training paired with simulated phishing campaigns

Security awareness training combined with simulated phishing campaigns directly targets the human vulnerability that phishing exploits. Repeated, measured campaigns have been shown to lower click rates over time and produce per-user and per-department trend metrics that can be reported to leadership — exactly the measurable outcome requested. Blocking all attachments breaks legitimate business workflows and only addresses one delivery vector, not the click behavior. Forced periodic password changes are deprecated industry guidance and do nothing to stop a user from typing credentials into a fake login page. Larger mail quotas have no security impact on phishing susceptibility.